ZEDPATH

Team Kestrel · IntelliCon '26 Buildathon

ZP-DOC-08

Test Plan

Test strategy, environments, test case catalogue, results and requirement traceability for Releases R1 and R2

Version	0.9
Status	In review
Date	23 October 2026
Classification	Public
Document owner	B.M.P Banneka, Product Owner

© 2026 Team Kestrel. Published under the classification shown above.

Uncontrolled when printed or exported. The controlled version is the Markdown source in the repository: docs/08-test-plan/ZP-DOC-08_Test-Plan.md

Document control

Document information

Document ID	ZP-DOC-08
Title	Test Plan
Version	0.9
Status	In review
Classification	Public
Document owner	B.M.P Banneka, Product Owner
Author	Team Kestrel (drafted with Claude, AI coding partner)
Conforms to	IEEE 829 / ISO/IEC/IEEE 29119-3 structure; ZP-DOC-00
Source file	docs/08-test-plan/ZP-DOC-08_Test-Plan.md
Repository	https://github.com/PraveenBanneka/zedpath

Revision history

Version	Date	Author	Description of change
0.9	11 Oct 2026	Team Kestrel	First issue: strategy, environments, Definition of Done, catalogue of the 19 automated test files (185 cases), security tests, results of 11 October 2026, defects found and fixed, gaps, traceability; submitted for approval
0.9	15 Oct 2026	Team Kestrel	Revised in review for VR2 and CR-007 to CR-010: catalogue extended to all 34 test files (TC-124 to TC-138: the eight suites of the 12 October campaign and the new demo, statistics, aptitude, session-kick, hardening and owner tests); counts recounted (532 passed, 0 expected-fail, 21 opt-in); migrations 0001 to 0012; security tests for the demo, Origin, socket kick, abuse limits, contact filter and research block list; security audit run-1 summarised (detail in the Test Summary Report); results of 15 October 2026; guard tests 40 of 40; gaps and traceability updated
0.9	21 Oct 2026	Team Kestrel	VR3: TC-139 added (desktop side menu preference, `src/nav-pref.test.ts`); results of 21 October 2026 (536 passed) and live checks of the Compare fixes and the desktop layout
0.9	23 Oct 2026	Team Kestrel	VR4: TC-140 added (added-to-list message, `src/list-feedback.test.ts`); 539 passed
0.9	23 Oct 2026	Team Kestrel	CR-011: TC-141 (list guide), TC-105 and TC-125 updated (no proposed order); 543 passed
0.9	23 Oct 2026	Team Kestrel	CR-012: TC-142 (application co-pilot); 547 passed
0.9	23 Oct 2026	Team Kestrel	CR-012 revised (guides instead of inputs): TC-142 extended; 549 passed

Review and approval

This document takes effect when the approver signs below. Until then its status is as shown on the cover.

Role	Name	Signature	Date
Reviewer	Claude (AI coding partner), consistency and traceability review		
Approver	B.M.P Banneka, Product Owner		

Contents

1 Introduction 6
1.1 Purpose 6
1.2 Scope 6
1.3 Intended audience 6
1.4 Relationship to other documents 6
2 Test strategy 7
2.1 Test levels 7
2.2 Test types 7
2.3 Approach 8
3 Test environment 9
4 Entry and exit criteria 10
4.1 Entry criteria 10
4.2 Exit criteria (Definition of Done) 10
4.3 Suspension and resumption 10
5 Test items and features 11
6 Test case catalogue 13
7 Security tests 19
8 Results summary 21
9 Defects found and fixed 23
10 Known gaps and risks 24
11 Traceability 25
Appendix A: Glossary 26
Appendix B: References 27

List of tables

Table 1: Position of this document in the ZedPath document set 6
Table 2: Test levels used 7
Table 3: Test types and where they are applied 7
Table 4: Environments 9
Table 5: Features under test 11
Table 6: Automated test cases 13
Table 7: Security tests 19
Table 8: Results 21
Table 9: Results of 21 October 2026 (developer machine) 21
Table 10: Results of 15 October 2026 (developer machine, commit f704d0b) 22
Table 11: Defects found by testing and fixed 23
Table 12: Known gaps 24
Table 13: Requirements to test cases 25

Table 14: Terms used in this document 26
Table 15: Sources referred to in this document 27

1 Introduction

1.1 Purpose

This document states how ZedPath is tested, what is tested, on what, and with what result. It follows the structure of IEEE 829 and ISO/IEC/IEEE 29119-3 (test plan and test summary content), scaled to a three-week buildathon product. It also gives the matrix from requirement to test case that ZP-DOC-00 requires of this document.

1.2 Scope

All software of Releases R1 and R2 as live on 11 October 2026, and as built on 15 October 2026 (VR2 and CR-007 to CR-010): the React single-page app, the Hono API in one Cloudflare Worker, the D1 database and its migrations 0001 to 0012, the group-room Durable Object, Ask ZedPath, and the project's safety tooling (deploy guard and leak scanner). Out of scope: features not yet built (results-photo reading, curator review queue, Gazette job, share card, teacher view) and third-party services themselves (Gemini, Cloudflare platform), which are tested only through ZedPath's handling of their answers.

1.3 Intended audience

Developers, the product owner, buildathon judges and anyone assessing whether ZedPath does what its requirements say.

1.4 Relationship to other documents

Table 1: Position of this document in the ZedPath document set

Document	Relationship
ZP-DOC-02 User Stories	Parent. Acceptance criteria (AC-*enn.k*) are the basis of many test cases
ZP-DOC-03 SRS	Parent. Each FR, NFR and BR with verification method T (test) traces to a test case here
ZP-DOC-05 Data Design	Parent. Database rules (CHECK, FK, triggers) are tested on the real migrations
ZP-DOC-08 Test Summary Report	Companion. Reports the executed results of the two end-to-end agent harnesses (Section 2.1)
`WORKLOG.md`	Record. Each deploy's live check and version is logged there

2 Test strategy

2.1 Test levels

Table 2: Test levels used

Level	What it exercises	How	When
Unit	Pure shared logic: rule engine, banding, list rules, journey dates, contact parsing, message rules, key derivation, answer layout, i18n dictionaries	Vitest, no I/O	Every change
Integration on real migrations	The API with its database: every route against an in-memory SQLite built from the real `migrations/*.sql` files (`worker/testing/d1-sqlite.ts`), so CHECKs, foreign keys, triggers and cascades are those of production	Vitest calling the Hono app directly	Every change
API contract (pinned)	Answers that must not drift, such as `POST /api/results` before and after the Ask refactor	Snapshot-equal assertion	Every change
E2E API (agent harness)	110+ HTTP cases against the local server (`wrangler dev --local`): sign-up, sessions, journey windows, groups, Ask switches, validation	`tools/e2e/api-e2e.ts`, run by an agent	Before final submission
E2E UI (agent-browser harness)	30+ click-through cases in a real browser at phone size	agent-browser, run by an agent	Before final submission
Manual and exploratory	Whole flows by a person: product-owner screen-recorded reviews, developer click-throughs at 390 x 844	Browser and Android phone	Each feature
Live smoke after deploy	The deployed version on the public URL, with a throwaway account deleted afterwards	Scripted HTTP checks plus a browser	After every deploy

The executed results of the two end-to-end harnesses are reported in the companion **ZP-DOC-08 Test Summary Report** (`docs/08-test-plan/ZP-DOC-08_Test-Summary-Report.md`), not here.

2.2 Test types

Table 3: Test types and where they are applied

Type	Applied to
Functional	Every user-facing rule: eligibility, bands, list, journey, groups, Ask, accounts
Security	Session checks, server-side enforcement, rate limits, cross-site write refusal, key derivation vectors, deploy guard, leak scanner (Section 7)
Data integrity	Database CHECK, FK, unique and trigger rules exercised with bad rows; delete cascades ("wipe check")
Data migration	Each migration applied in order in tests; 0010 expand-then-contract: rules accepted under 0009 are carried over and the old column kept so a code rollback stays safe

Type	Applied to
Safe default (pinned)	Defaults that equal earlier behaviour are pinned by tests: no database means no accounts but results still work; notification settings default to 7 and 1 days at 08:00; demo mode off by default
Internationalisation parity	Sinhala and Tamil dictionaries have exactly the English keys, keep placeholders and bold tags, and are in the right script
Accessibility	Manual: 48 dp touch targets, 360 px width without horizontal scroll, contrast in the Material 3 theme (no automated audit yet)
Performance budget	Manual and by inspection: Worker CPU under the free-plan 10 ms, bundle size; no load test (Section 10)
Trust rules	Every Ask citation exists; sample conversations are labelled; never "you will get in"

2.3 Approach

Business rules are pure functions in `shared/` (NFR-060), so they are tested without a server. Server rules are tested through the real HTTP routes on the real schema, never by calling internals. Each bug found by hand gets a test before or with its fix. Any change to a default value comes with a test that pins the default.

3 Test environment

Table 4: Environments

Environment	Detail
Developer machine	Windows 11, Node.js, TypeScript (`tsc -b`), Vitest 4.1
Test database	In-memory SQLite loaded with `migrations/0001` to `0012` by `worker/testing/d1-sqlite.ts`
Local server	`npm run build` then `wrangler dev --local` (local D1, no remote resources). The built copy is served, so a build precedes every local test
Browsers	Chromium via agent-browser at 390 x 844; desktop Chrome
Phone	Android phone with the installed app (Capacitor) and the PWA
Production	Cloudflare Workers free plan, reached only through the GO-gated deploy sequence; checked with a throwaway account

Ask ZedPath is not called against the live Gemini model in automated tests; the model is replaced by fixed replies, to protect the free quota.

4 Entry and exit criteria

4.1 Entry criteria

A change enters testing when it builds, its design is recorded (data changes in ZP-DOC-05 first) and, for a change request, the product owner has approved it.

4.2 Exit criteria (Definition of Done)

A change is done only when all of the following hold:

1. `npx tsc -b` reports no errors. (`tsc -p .` is not used: the root `tsconfig.json` has `files: []`, so it checks nothing.)
2. `npx vitest run` passes every test, including pinned defaults.
3. `npm run build` is green.
4. The key flow is clicked through on the local build.
5. The deploy is made only after `wrangler whoami` shows the ZedPath account and the product owner replies **GO**.
6. The live version is checked on the public URL (a channel that can see it), with a database backup first when a migration runs.
7. Version, checks and rollback target are logged in `WORKLOG.md` and committed.

4.3 Suspension and resumption

Testing stops when the test channel itself fails (for example, a local server serving an old build); the channel is fixed first, then testing resumes. After one failed fix, the next step is instrumentation, not a second patch.

5 Test items and features

Table 5: Features under test

Feature	Main code	Test files
Eligibility rule engine	`shared/rules.ts`	`shared/rules.test.ts`
Safe/Likely/Reach banding	`shared/banding.ts`	`shared/banding.test.ts`, `worker/results.test.ts`
Search	`shared/search.ts`	`shared/search.test.ts`
My list	`shared/list.ts`	`shared/list.test.ts`
Journey and reminders	`shared/journey.ts`, `worker/my-journey.ts`	`shared/journey.test.ts`, `worker/my-journey.test.ts`
Accounts and contact details	`worker/account.ts`, `shared/contact.ts`, `shared/kdf.ts`	`worker/account.test.ts`, `shared/contact.test.ts`, `shared/kdf.test.ts`
Groups	`worker/groups.ts`, `worker/group-room.ts`, `shared/groups.ts`	`worker/groups.test.ts`, `shared/groups.test.ts`
Ask ZedPath	`worker/ask.ts`, `shared/answer.ts`, `src/ask-suggest.ts`	`worker/ask.test.ts`, `shared/answer.test.ts`, `src/ask-suggest.test.ts`
Degree syllabi	`worker/syllabi.ts`	`worker/syllabi.test.ts`
Interface languages	`src/i18n`	`src/i18n/i18n.test.ts`
Demo mode and notifications	`src/demo.ts`, `src/notify.ts`	`src/demo.test.ts`, `src/notify.test.ts`
Deploy guard and leak scanner	`.claude/hooks/zedpath-guard.cjs`, `.githooks/leak-scan.cjs`	`.claude/hooks/test-guard.sh`
Try the demo (CR-007)	`worker/account.ts` (`/auth/demo`), `shared/demo-data.ts`, migration 0011	`worker/demo-login.test.ts`, `worker/demo-data.test.ts`, `src/demo.test.ts`, `worker/hardening.test.ts`
University facts (CR-008)	`tools/statistics/build-statistics.ts`, `shared/statistics.ts`, `worker/index.ts`	`worker/statistics.test.ts`
Aptitude tests (CR-009)	`data/aptitude/aptitude-2025-2026.json`, `worker/index.ts` (`aptitudeFor`)	`worker/aptitude.test.ts`
Security hardening (CR-010)	`worker/account.ts`, `worker/groups.ts`, `worker/group-room.ts`, `worker/ask.ts`, `shared/groups.ts`, `src/storage.ts`, migration 0012	`worker/session-kick.test.ts`, `worker/hardening.test.ts`, `worker/groups.test.ts`, `worker/groups.e2e.test.ts`, `src/owner.test.ts`
Research block list (CR-010)	`tools/research/blocked-pages.ts`, `tools/research/check-url.ts`	`worker/data-integrity.e2e.test.ts` (DAT-054)
Data, schema, accuracy and performance (12 October campaign)	`data/`, `migrations/`, `worker/`, `shared/`	`worker/accuracy.e2e.test.ts`, `worker/data-integrity.e2e.test.ts`, `worker/migrations.e2e.test.ts`, `worker/perf.e2e.test.ts`, `shared/journey.e2e.test.ts`, `shared/list.e2e.test.ts`, `worker/ask.e2e.test.ts`, `worker/groups.e2e.test.ts`

6 Test case catalogue

Each automated test file is one test case group. The case count is the number of `it` cases Vitest ran on 15 October 2026 at commit f704d0b (first issue: 11 October 2026; TC-112 and TC-118 have grown since).

Table 6: Automated test cases

TC	Feature	Test file (cases)	What it proves	Trace
TC-101	Rule engine	`shared/rules.test.ts` (18)	General minimum, handbook examples (Medicine, Computer Science, Physical Science), Arts basket rules and exceptions, stream and O/L checks	BR-001, BR-010, BR-020, BR-022, FR-201, FR-202, FR-113, AC-201.3
TC-102	Banding	`shared/banding.test.ts` (14)	Pinned thresholds; exact four-decimal Z-scores; Safe/Likely/Reach/Out of range; limited history; NQC years; trend	BR-030 to BR-036, FR-102, FR-205, FR-206, NFR-051
TC-103	Results API	`worker/results.test.ts` (1)	`POST /api/results` answer unchanged by the Ask refactor (pinned contract)	FR-201, FR-203, FR-205
TC-104	Search	`shared/search.test.ts` (4)	Word-start matching in any order, Uni-Codes and short forms	FR-123, FR-215
TC-105	My list	`shared/list.test.ts` (7)	Only eligible, no duplicates, 125 cap; order notes (never a re-order, CR-011); copy Uni-Codes; multi-add	FR-302 to FR-306, FR-308, FR-310, BR-041 to BR-043
TC-106	Journey rules	`shared/journey.test.ts` (16)	Official notices with sources; age and subject eligibility; UNKNOWN never a guess; ordering; reminders 7 and 1 days at 08:00; calendar file; pinned default settings	FR-401, FR-403, FR-404, FR-412, FR-413, FR-509, FR-510, NFR-072
TC-107	Journey on account	`worker/my-journey.test.ts` (11)	Migration 0010 fills 255 offerings; CHECK and shared step list agree; 0009 rules carried over; session required; starts empty; follow real items only; tick only when open (409); deleted with account; Sri Lanka date; avatar values	FR-409, FR-410, FR-411, FR-414 to FR-416, FR-122, BR-061, NFR-038

TC	Feature	Test file (cases)	What it proves	Trace
TC-108	Accounts	`worker/account.test.ts` (26)	Migration 0003 and 0007 rules; sign-up, log-in, one failure message; own rows only; atomic save; log out everywhere; expiry; recovery code; delete cascade; cross-site refusal; rate limits; safe default without database; compulsory contact details	FR-114 to FR-121, NFR-030, NFR-035 to NFR-037, NFR-070
TC-109	Contact parsing	`shared/contact.test.ts` (5)	Sri Lankan mobile formats; refusals; first wrong field named; age with birthday	FR-120, NFR-070
TC-110	Key derivation	`shared/kdf.test.ts` (3)	PBKDF2-HMAC-SHA256 published vectors; 600 000 rounds pinned; key format	NFR-036
TC-111	Group message rules	`shared/groups.test.ts` (12)	Clean text; rate limit 3 s and 20 per 10 min; moderation fails closed; hidden and blocked; no contact details; sample conversations labelled	FR-708, FR-709, FR-711, FR-712, FR-716, NFR-039
TC-112	Groups API	`worker/groups.test.ts` (17)	Migrations 0005 and 0006 rules; senior invite once; session required; rules once per account; members only, usernames never names; report threshold of 3; *(CR-010)* reports from accounts under a day old do not count; block; delete wipes memberships and messages	FR-703, FR-705, FR-707, FR-710, FR-711, FR-714, FR-715, FR-717, FR-718, FR-720, NFR-038, NFR-071
TC-113	Ask ZedPath	`worker/ask.test.ts` (24)	Off until configured; server validation; citations exist and point to passages; engine facts; https-only links; 30 a day per device; model fallback; developer tools off; verdict, actions, anonymous feedback; leaked model reasoning never shown	FR-601 to FR-612, FR-913, NFR-034, NFR-040, NFR-050
TC-114	Answer layout	`shared/answer.test.ts` (7)	Sentences split without breaking citations, decimals or "No. 16"; lead line and bullets; Sinhala and Tamil	FR-608

TC	Feature	Test file (cases)	What it proves	Trace
TC-115	Ask suggestions	`src/ask-suggest.test.ts` (4)	Suggestions from the student's own details; general fallback; Sinhala and Tamil placeholders filled	FR-602, FR-610
TC-116	Syllabi	`worker/syllabi.test.ts` (4)	Official curriculum with source; unsafe source never served; cache key tied to data	FR-209, NFR-050
TC-117	Languages	`src/i18n/i18n.test.ts` (7)	Sinhala and Tamil have exactly the English keys, placeholders and tags, and the right script	FR-112, NFR-023, FR-124
TC-118	Demo mode	`src/demo.test.ts` (4)	Off by default; prefills only details the server accepts; *(VR2)* a national sports achievement; *(CR-010)* never ships a password	Trust rule (sample data labelled); FR-128, NFR-078
TC-119	Test notification	`src/notify.test.ts` (4)	One native notification with a stable id; explains denial; reports unsupported	FR-412
TC-120	Deploy guard	`.claude/hooks/test-guard.sh` (40)	Blocks account switching, salon access, deploys without GO, writes to other repositories; allows local work	NFR-033; project rules
TC-121	E2E API harness	`tools/e2e/api-e2e.ts` (110+)	The built API on the local server, end to end	See Test Summary Report
TC-122	E2E UI harness	agent-browser (30+)	Main flows in a real browser at phone size	See Test Summary Report
TC-123	Live smoke	Manual, per deploy	Live version answers as tested locally	Section 8
TC-124	Journey logic (campaign)	`shared/journey.e2e.test.ts` (39)	Step windows, notice ticks, step ids against the D1 CHECK, reminder settings and times, calendar file, Sri Lanka date	FR-401, FR-404, FR-409, FR-410, FR-412, FR-413, FR-415, BR-061 to BR-063
TC-125	My list and Compare (campaign)	`shared/list.e2e.test.ts` (36)	Eligibility, duplicates, 125 cap, multi-add, reorder, order warnings, Compare selection of 3 in order, storage round trip; *(CR-010)* wrong-shaped storage reads as empty (LST-036, D-12)	FR-301 to FR-311, BR-041 to BR-043

TC	Feature	Test file (cases)	What it proves	Trace
TC-126	Data accuracy (campaign)	`worker/accuracy.e2e.test.ts` (75)	Every Uni-Code, district and cut-off equals the official UGC tables, read independently of the engine; band boundaries; subject rules by stream; a higher Z-score never gives a worse band	BR-001 to BR-036, FR-201, FR-205, NFR-050, NFR-052
TC-127	Ask (campaign)	`worker/ask.e2e.test.ts` (46)	Verdict line, leaked-reasoning filter, layout, citations and https links, validation, model fallback order, daily allowance, suggestions; no network	FR-601 to FR-612, NFR-034
TC-128	Data integrity (campaign)	`worker/data-integrity.e2e.test.ts` (54)	Route ids, compiled Journey, ISO dates on the Sri Lanka day (DAT-011), no invented UGC dates, official https links never blocked, a source for every number, three languages; *(CR-010)* DAT-054: no URL is a page blocked during research	NFR-050, NFR-054, FR-402, FR-502
TC-129	Groups (campaign)	`worker/groups.e2e.test.ts` (30)	Contact filter, message limits, rules version against the D1 CHECKs, labelled samples, members and badges, cross-site writes refused; *(CR-010)* GRP-012 to GRP-016 (disguised contact details) now plain passing tests	FR-708, FR-712, FR-716, FR-723, NFR-071, NFR-076
TC-130	Migrations (campaign)	`worker/migrations.e2e.test.ts` (30)	Migrations apply cleanly; STRICT tables, keys, CHECKs, indexes; reference counts; the deletion cascade; expand-then-contract	ZP-DOC-05; NFR-075
TC-131	CPU budget (opt-in)	`worker/perf.e2e.test.ts` (21, run with `PERF=1`)	In-process cost of the heaviest routes against the 10 ms CPU limit; payload sizes	NFR-005, NFR-006
TC-132	Demo student	`worker/demo-data.test.ts` (1)	The sample student's achievements and interests pass the server's own checks unchanged	FR-125

TC	Feature	Test file (cases)	What it proves	Trace
TC-133	Try the demo	`worker/demo-login.test.ts` (9)	Migration 0011 rule and partial index; one tap logs in with the sample student, marked demo; a private copy per visitor; no password log-in; expired demos and all their rows deleted, real accounts untouched; cross-site, "null" and malformed Origin refused with 403; joins existing groups only; cannot report; the room is told it is read-only	FR-125 to FR-127, BR-059, NFR-076
TC-134	University facts	`worker/statistics.test.ts` (5)	Values equal the hand-checked printed tables; caveats kept (provisional, incomplete; no Mahapola/Bursary line); every fact cites an official https UGC page; facts served on the course page; weak ETag answered with 304 (D-05)	FR-219, NFR-007, NFR-055, BR-081
TC-135	Aptitude tests	`worker/aptitude.test.ts` (5)	All 24 offerings covered; last intake shown as past; joint practical test points to the universities that hold it; no card without a test; official https links only, never an unread date	FR-220, BR-064
TC-136	Session kick	`worker/session-kick.test.ts` (5)	Log out closes only this device's sockets; log out everywhere and recovery close every device's; leaving closes that group only; Ask refuses a "null" or malformed Origin with 403; deletion purges a room the student opened and then left (migration 0012)	FR-132, FR-914, NFR-076, NFR-077

TC	Feature	Test file (cases)	What it proves	Trace
TC-137	Abuse limits	`worker/hardening.test.ts` (7)	IPv6 limited per /64; 100 writes a minute per account; whole-service Ask cap; feedback daily cap and one-year retention; at most 500 demo accounts and clean-up of 50 per tap; developer tools refuse cross-site; email length checked before the pattern	FR-126, FR-614, FR-615, NFR-081 to NFR-083
TC-138	Phone owner	`src/owner.test.ts` (2)	Local data remembers its owner and only that student's data is cleared for the next one (language stays); clearing the phone forgets the owner	FR-130
TC-139	Desktop side menu	`src/nav-pref.test.ts` (4)	Open by default (pinned); collapsed and open remembered; open and no error when storage is blocked; "Clear this phone" forgets it, clearing student data keeps it	ZP-DOC-07 Desktop layout
TC-140	Added confirmation	`src/list-feedback.test.ts` (3)	Counts one and several; mentions courses already on the list and a full list; never says "Added 0"	ZP-DOC-07 Added confirmation
TC-141	List guide (CR-011)	`src/list-guide.test.ts` (4)	Six UGC rules, each with a handbook page or section, in all three languages; order by preference; the old proposed order is gone	FR-312; AC-302.4
TC-142	Application co-pilot (CR-012)	`src/apply.test.ts` (6)	UGC formats (BANDARA DPS, 07… mobile); checklist fits school or private, O/L, affidavit, aptitude (singular for one course); every step cites the handbook in three languages; six guides instead of inputs; first-version typed details deleted on load; only two answers and ticks kept, cleared with the student's data	FR-313 to FR-316

7 Security tests

Table 7: Security tests

Threat	Control	Test
Deploy to the wrong account or without approval	Guard blocks deploys unless `wrangler.jsonc` pins the ZedPath account and the latest message starts with GO; blocks login, logout and account switching	TC-120
Secret in the public repository	`.githooks/leak-scan.cjs` scans every new commit on push for API keys, private keys, `.env` and `.dev.vars` files and a forbidden account fingerprint; blocks the push on a hit	Runs on every push; full history with `--all`
Access without a session	Journey, groups and `/me` routes answer 401 without a session	TC-107, TC-108, TC-112; live check
Client-only enforcement	Server refuses a tick before its window (409), an unknown course, a bad avatar (400), a join without rules	TC-107, TC-112; live check
Reading other students' data	Every query is scoped to the session's account; tests try another account's rows	TC-108
Password guessing	11th guess at one account within a minute blocked; sign-up and log-in rate limits	TC-108
Cross-site requests	Writes from other origins refused	TC-108
Contact details shared in groups	`CONTACT_RE` in `shared/groups.ts` refuses phone numbers in any spacing and emails, but keeps Z-scores and years	TC-111
Harmful messages	Moderation fails closed when its answer cannot be read	TC-111
Model shows its own reasoning or instructions	`usableReply` in `worker/ask.ts` rejects replies that talk about their instructions; "thought" parts dropped; next model asked	TC-113
Unsafe links in answers	https only, spaces escaped; the unsafe syllabus source never served	TC-113, TC-116
Weak password storage	PBKDF2 at 600 000 rounds on the device, published vectors	TC-110
Cross-site, "null" or malformed Origin (D-03)	`crossSite()` shared by every write route and both Ask routes: 403, never 500, nothing written	TC-133, TC-136, TC-129
Demo accounts misused	Private copy per tap; no password log-in; 24-hour expiry; at most 500 live; read-only in groups; no demo password shipped	TC-133, TC-137, TC-118

Threat	Control	Test
A chat left open after log-out (audit lead 2) or messages left after deletion (lead 3)	`/kick` to each room for the session or account; deletion purges every room in `group_member` or `group_room_seen`	TC-136
Floods and quota exhaustion (leads 8, 10 to 14)	Per-account write budget; IPv6 /64 buckets; whole-service Ask cap; feedback cap; post attempts counted before moderation; three sockets per account; `/live` rate limit	TC-137 (leads 8, 10 to 12); leads 13 and 14 (inside the group-room Durable Object) by inspection
Disguised contact details (lead 16, D-04)	Contact filter on a normalised copy	TC-129, TC-111
Report flooding by fresh accounts (lead 4)	Only accounts a day old and not demo count toward hiding	TC-112
The next student on a shared phone (lead 7)	Local data tagged with its owner, cleared for another student	TC-138
Link that spends questions (lead 15), failed log-out shown as success (lead 6)	`#/ask/` only fills the box; log-out failure reported	Inspection and manual check (no automated test)
Unsafe research pages	Page-level fingerprints; check-url tool before fetching; DAT-054 over all data	TC-128

Security audit run-1 (15 October 2026). The Cloudflare security-audit skill (37 agents, report kept outside the public repository) produced 0 confirmed findings, 17 leads needing validation and 1 rejected lead. Every lead except lead 9 (accepted risk: the log-in limit stays per username because school laboratories share an address; a Turnstile human check is planned) was fixed on 15 October 2026. The method, each lead, its fix and its test are listed in the ZP-DOC-08 Test Summary Report.

8 Results summary

Executed on 11 October 2026 on the developer machine, at commit `349f041` plus uncommitted documents.

Table 8: Results

Check	Result
`npx vitest run`	**19 test files, 185 tests, 185 passed, 0 failed** (about 3 s)
`npx tsc -b`	Exit code 0, no errors
`bash .claude/hooks/test-guard.sh`	**35 passed, 5 failed** of 40. The 5 failures are stale expectations: the test file still names the old repository `zedpath`, while the guard (edit not yet committed) allows the renamed repository. The guard blocks correctly; the test file needs updating (Section 10)
Leak scanner	Ran on every push; no push blocked by a real secret on 11 October 2026
Live smoke, version f589f1a8 (migration 0010)	Sign-up 201; journey empty; follow course and notice 204; tick RESULTS 204; tick UGC_APPLY 409 (not open); avatar 200, bad avatar 400; `/api/me/journey` 401 without session; DELETE `/me` 204 with journey rows cascaded to 0
Live smoke, versions 40628ac5 and ef419fb6	Back from Create account lands on Welcome, in a fresh browser and with the old onboarded flag set
Live smoke, versions 413c11d5 and 7ab12039	Demo link fills the sign-up form; then the plain start link is still filled; without the demo link, empty
E2E API and UI harnesses	Reported in the ZP-DOC-08 Test Summary Report

Automated test count over the build: 79 (5 October), 126, 152, 164, 179, 185 (11 October), 515 with 6 expected-fail and 21 opt-in (12 to 15 October, after the test campaign and CR-007 to CR-009), 532 with 0 expected-fail and 21 opt-in (15 October, after the hardening of CR-010), 536 (21 October, after VR3 and the desktop side menu, TC-139), 539 (23 October, after VR4, TC-140), 543 (23 October, after CR-011, TC-141), 547 (23 October, after CR-012, TC-142), 549 (23 October, CR-012 revised to guides).

Table 9: Results of 21 October 2026 (developer machine)

Check	Result
`npx vitest run`	**35 test files (34 passed, 1 opt-in skipped); 557 tests: 536 passed, 0 failed, 0 expected-fail, 21 skipped (the opt-in CPU budget, TC-131)**
`npx tsc -b`	Exit code 0, no errors
`bash .claude/hooks/test-guard.sh`	**40 passed, 0 failed** of 40
Live check, version 2b11af0d (VR3 Compare fixes)	Courses at 390 × 844 in the demo: tip box shown; 4 ticked: Compare off and the limit message above the bar, buttons on one row; 2 ticked: Compare, then "+" opens the picker; the added course's column fully visible beside the labels
Live check, versions dd209eea, 709586ee and 209a0c04 (desktop layout)	Paths and course 081E at 1440 × 900, 1871 × 900 and 1280 × 800; Paths at 390 × 844 unchanged (screenshots compared pixel by pixel apart from the ring animation)

Table 10: Results of 15 October 2026 (developer machine, commit f704d0b)

Check	Result
`npx vitest run`	**34 test files (33 passed, 1 opt-in skipped); 553 tests: 532 passed, 0 failed, 0 expected-fail, 21 skipped (the opt-in CPU budget, TC-131)**
`npx tsc -b`	Exit code 0, no errors
`bash .claude/hooks/test-guard.sh`	**40 passed, 0 failed** of 40 (test file updated for the renamed repository on 14 October 2026)
Live smoke, version 59ad7760 (migration 0011, CR-007)	Demo tap 201 with the sample student and `demo: true`; `/me` 200; report 403 (demo read-only); Origin "null" 403 (D-03); DELETE `/me` 204, then 401; the two test demo accounts deleted
CR-008 to CR-010	Built and tested locally on 15 October 2026; the live check follows their deploy and is logged in `WORKLOG.md`

9 Defects found and fixed

Table 11: Defects found by testing and fixed

Defect	Found by	Fix and regression test
`tsc -p .` reported success while checking no files (root `files: []`)	Code review	Definition of Done uses `tsc -b`, which checks every project
Two posts handled concurrently: the second skipped the rate limit and could overtake the first	Local end-to-end, two users	Posts processed in order in the room; rate-limit tests in TC-111
Non-ASCII senior badge header broke the room	Local end-to-end	Header URI-encoded
Back from Create account looped to sign-up on phones that already had the onboarded flag	Product owner's review, then live check	Back while logged out clears the flag and opens Welcome (ef419fb6); live-checked with the old flag set. Lesson: test the user's actual state, not a fresh browser
Demo mode lost in the installed app (plain start link)	Live check	Demo mode remembered on the phone, saved on first open of the demo link; TC-118
Model's reasoning text shown as an answer	Product owner's review	`usableReply` plus dropped thought parts, next model asked; TC-113
Group room showed "Disconnected" at random	Product owner's review	Keep-alive at least every 25 s answered without waking the room, silent reconnect (FR-719, NFR-043)
Ask citations showed research-note file names that looked like broken links	Product owner's video review	Routes shown by name and official document; TC-113
Local tests ran an old build	Developer	Build before every local test (environment rule)

The product owner's screen-recorded reviews produced change requests CR-001 to CR-006; each was designed in ZP-DOC-05 first and arrived with its own tests.

10 Known gaps and risks

Table 12: Known gaps

Gap	Risk	Plan
Guard test file expected the old repository name. *Closed 14 October 2026:* `test-guard.sh` updated, 40 of 40 pass	None now	None
Audit run-1 leads validated by tests, not by exploitation (no sandbox)	A fix may not close the real attack path	Re-run the audit on a separate staging environment once it exists
Leads 6 and 15 (client behaviour) and leads 13 and 14 (inside the group-room Durable Object) have no automated test	A regression would not be caught	Add 6 and 15 to the browser harness and 13 and 14 to the WebSocket check (`tools/e2e/ws-check.ts`)
No staging environment	Live smoke runs on production with throwaway accounts	Create a separate staging Worker and database
No automated accessibility audit (NFR-021)	WCAG 2.2 AA not proven	Add an axe or Lighthouse pass to the UI harness
No load or CPU test (NFR-003, NFR-005, NFR-010)	Free-plan limits under results-day load unknown	Measure CPU per route with `wrangler dev` and a load test before the next admission season
Ask not exercised against the live model in tests	Model behaviour changes are not caught	Small, quota-capped live prompt set
Branch coverage not measured (NFR-061)	Rule-engine branches may be untested	Add Vitest coverage with a 90% branch threshold
Sinhala and Tamil not reviewed by native speakers	Wrong wording	Native review (FR-124 label shown until then)
Usability target NFR-020 (5 participants) not yet run	Time to a checked list unknown	Moderated sessions with students

11 Traceability

The test case catalogue (Section 6) traces each test case to its requirements. The table below gives the reverse view: each requirement area of ZP-DOC-03 with verification method T, to the test cases that prove it.

Table 13: Requirements to test cases

Requirement area (ZP-DOC-03)	Test cases
FR-101 to FR-124 (profile, accounts, languages)	TC-101, TC-102, TC-104, TC-108, TC-109, TC-117, TC-107 (FR-122)
FR-125 to FR-132 (demo, owner, deletion purge)	TC-118, TC-132, TC-133, TC-136, TC-137, TC-138; FR-129 and FR-131 by manual check
FR-201 to FR-218 (eligibility, bands, compare)	TC-101, TC-102, TC-103, TC-104, TC-116, TC-126; FR-207, FR-213, FR-216 to FR-218 by manual review
FR-219 to FR-221 (university facts, aptitude, band names)	TC-134, TC-135; FR-221 by inspection
FR-511 (NVQ ladder)	TC-128 (links and sources) and inspection
FR-613 to FR-615 (Ask link, feedback and service caps)	TC-137; FR-613 by inspection
FR-720 to FR-723, FR-914 (group hardening, session kick)	TC-112, TC-129, TC-136; FR-721 and FR-722 by inspection
FR-301 to FR-311 (my list)	TC-105; FR-301, FR-309, FR-311 by manual click-through
FR-401 to FR-417 (journey, reminders)	TC-106, TC-107, TC-119
FR-501 to FR-510 (other paths, notices)	TC-106 (FR-509, FR-510); FR-501 to FR-503 by manual review
FR-601 to FR-612 (Ask)	TC-113, TC-114, TC-115
FR-701 to FR-719 (groups)	TC-111, TC-112; FR-719 by manual and live check
FR-913 (Ask rate limit)	TC-113
BR-001 to BR-043	TC-101, TC-102, TC-105
BR-061 (tick windows)	TC-107
NFR-023	TC-117
NFR-030, NFR-035 to NFR-039	TC-108, TC-110, TC-111, TC-112, TC-107
NFR-033	TC-120 and the leak scanner
NFR-040, NFR-050, NFR-051	TC-113, TC-116, TC-102
NFR-070 to NFR-072	TC-108, TC-109, TC-112, TC-106
NFR-007, NFR-054, NFR-055	TC-134, TC-128
NFR-076 to NFR-083 (security hardening)	TC-118, TC-133, TC-136, TC-137, leak-scanner self-check (NFR-080); NFR-079 by inspection
BR-037, BR-059, BR-064, BR-078, BR-079, BR-081	TC-133, TC-137, TC-135, TC-112, TC-134; BR-037 and BR-079 by inspection
NFR-001 to NFR-006, NFR-010, NFR-020, NFR-021, NFR-061	Not yet tested (Section 10)

Appendix A: Glossary

Table 14: Terms used in this document

Term	Meaning
D1	Cloudflare's serverless SQL database, built on SQLite
Definition of Done	The exit criteria every change meets before it counts as finished
E2E	End to end: the whole system exercised through its external interface
Expand-then-contract	A migration that adds the new structure but keeps the old one until the release is stable, so rolling back code stays safe
GO	The product owner's explicit approval, a message starting with "GO", required for every deploy
Opt-in test	A test that runs only when asked (here, `PERF=1`), because its timing depends on the machine
Pinned test	A test that fixes a default or an answer so that any change to it is deliberate
Security audit run-1	The first run, on 15 October 2026, of the Cloudflare security-audit skill against the repository
Smoke test	A short check that the deployed version works on its main paths
TC	Test case
Throwaway account	A test account made on production for a live check and deleted straight after
Wipe check	A test that deleting an account removes every row and message under it, and nothing of anyone else

Appendix B: References

Table 15: Sources referred to in this document

Ref	Source
[1]	IEEE 829-2008, *Standard for Software and System Test Documentation*
[2]	ISO/IEC/IEEE 29119-3:2021, *Software testing, Part 3: Test documentation*
[3]	ZP-DOC-02 User Stories; ZP-DOC-03 Software Requirements Specification; ZP-DOC-05 Data Design
[4]	ZP-DOC-08 Test Summary Report (companion)
[5]	Vitest documentation, vitest.dev
[6]	OWASP Password Storage Cheat Sheet (PBKDF2 work factor), 2023
[7]	RFC 6070, *PKCS #5: PBKDF2 Test Vectors*